

Software Requirement Specification (SRS)

Project Name: Cloud-Based E-Commerce Platform (CECP)

Version: 1.0

Date: September 2024

Author: SecureCommerce Development Team

1. Introduction

1.1 Purpose

The purpose of this document is to define the functional and non-functional requirements for the Cloud-Based E-Commerce Platform (CECP). This system allows businesses to manage their online storefronts, process transactions, and handle customer data. The document outlines security specifications, including threat models and risk assessments, and provides an overview of asset management and environmental considerations.

1.2 Scope

CECP will provide users with the ability to manage product listings, process customer orders, and handle financial transactions. The platform will also support customer account management and store sensitive customer data securely.

2. Functional Requirements

FR1: The system shall allow users to create and manage product listings.

FR2: Customers shall be able to securely purchase items using various payment methods (credit card, PayPal, etc.).

FR3: The system shall support real-time inventory management.

FR4: Users shall be able to track order status and receive notifications.

FR5: The system shall generate financial reports and transaction summaries.

3. Non-Functional Requirements

Performance: The platform must support up to 10,000 concurrent users with a response time of less than 2 seconds for most operations.

Reliability: The platform should provide 99.95% uptime.

Scalability: The platform must be able to scale automatically to handle increased traffic during peak times.

Compliance: The platform must comply with PCI-DSS for payment processing and GDPR for user data protection.

4. Security Specification

4.1 Security Objectives

The main security objectives for the CECP are:

Confidentiality: To protect customer information (personal and financial) from unauthorized access.

Integrity: To ensure that product, transaction, and customer data cannot be altered without proper authorization.

Availability: To ensure that the platform is available to legitimate users at all times, even during attacks.

4.2 Authentication and Access Control

All users must authenticate using multi-factor authentication (MFA).

Role-based access control (RBAC) will be implemented to restrict access to sensitive administrative features.

4.3 Encryption

All sensitive customer data, including credit card details, must be stored encrypted using AES-256 encryption.

TLS 1.3 must be used for all data transmitted between clients and servers to ensure secure communication.

4.4 Auditing and Monitoring

The system shall maintain immutable logs for all sensitive actions, including login attempts, order placements, and data modifications.

A real-time intrusion detection system (IDS) will be implemented to monitor for suspicious activities and trigger alerts.

4.5 Threat Model and Risk Assessment

4.5.1 Threat Model Overview

This threat model follows the STRIDE framework to identify potential threats to the system, and a risk assessment is performed to determine the severity of each risk.

4.5.2 Risk Assessment of Assets

Customer Data: Personal identifiable information (PII), payment details, and order history.

Transaction Data: Information on payment transactions, order confirmations, and delivery statuses.

User Credentials: Usernames, passwords, and MFA tokens for customer and administrative access.

System Availability: Ensuring continuous availability of the platform to users for e-commerce transactions.

4.5.3 Identified Threats and Mitigation

Spoofing

Threat: Attackers impersonating legitimate users to gain access to customer accounts and sensitive data.

Risk Level: High

Likelihood: Moderate

Impact: High (compromise of customer accounts and transactions).

Mitigation:

Enforce multi-factor authentication (MFA) for all user logins.

Use OAuth 2.0 for secure authentication between external services.

Implement session monitoring and automatic account lockout after repeated failed login attempts.

Tampering

Threat: Unauthorized alteration of transaction data, such as changing the order total or shipping address.

Risk Level: Critical

Likelihood: Low

Impact: High (financial fraud and delivery issues).

Mitigation:

Use digital signatures to ensure the integrity of transaction data.

All sensitive data must be hashed using SHA-256 for verification purposes.
Implement real-time audit logs for monitoring and alerts for unauthorized modifications.

Repudiation

Threat: Users denying making specific orders or changes to their accounts.

Risk Level: Medium

Likelihood: Moderate

Impact: Medium (dispute resolution issues and possible legal complications).

Mitigation:

Implement non-repudiation mechanisms, such as digital signatures for order placements.

Store immutable audit logs of all critical actions performed by users.

Information Disclosure

Threat: Unauthorized access to customer PII or financial data.

Risk Level: Critical

Likelihood: High

Impact: Very High (loss of customer trust, legal penalties under GDPR).

Mitigation:

Use AES-256 encryption for all sensitive customer and payment data at rest.

Encrypt all data in transit using TLS 1.3.

Restrict access to sensitive data using role-based access control (RBAC) and regularly review permissions.

Denial of Service (DoS)

Threat: Attackers overwhelming the system with traffic, rendering it unavailable to legitimate users.

Risk Level: High

Likelihood: Low

Impact: High (service unavailability, lost sales).

Mitigation:

Implement rate limiting and DDoS protection services.

Use auto-scaling infrastructure to absorb traffic surges and maintain availability.

Implement load balancing to ensure high availability even during attacks.

Elevation of Privilege

Threat: Attackers gaining administrative access to the system, allowing them to perform unauthorized actions.

Risk Level: Critical

Likelihood: Low

Impact: Very High (complete system compromise).

Mitigation:

Apply the principle of least privilege to all user roles.

Regularly conduct penetration testing to identify and fix privilege escalation vulnerabilities.

Require MFA for administrative accounts and critical actions.

5. Asset Specification

5.1 Physical Assets

Cloud Servers: Deployed on a cloud platform such as AWS or Azure, with redundancy and failover capabilities across regions.

Data Storage: Cloud storage for encrypted databases, ensuring both security and availability.

5.2 Digital Assets

Customer Data: PII (such as names, addresses, phone numbers) and purchase history.

Financial Data: Payment information (credit card details, payment processors).

Transaction Data: Records of all customer transactions, order confirmations, and shipment details.

API Keys: Used for secure interactions with third-party services such as payment processors and shipping services.

5.3 Critical Assets

Payment Data: Sensitive credit card and payment details must be securely handled and stored according to PCI-DSS requirements.

Encryption Keys: AES-256 encryption keys for securing data at rest, and TLS certificates for securing data in transit.

System Logs: Security and activity logs that provide a detailed record of all transactions and system activities.

6. Environmental Assessment

6.1 Operating Environment

The CECP will be hosted in a cloud environment that supports high availability, load balancing, and disaster recovery.

The platform must be compatible with all major web browsers (Chrome, Firefox, Safari) and mobile devices (iOS, Android).

The backend must be compatible with Linux-based servers for security and performance reasons.

6.2 Regulatory Compliance

PCI-DSS: The platform must adhere to PCI-DSS standards for secure handling of payment card information.

GDPR: The platform must comply with GDPR regulations for protecting customer data and ensuring user privacy.

SOX: The system must provide an audit trail for financial transactions to comply with SOX requirements.

6.3 Disaster Recovery

The platform must have automated daily backups to ensure that all critical data can be restored in case of system failure.

Geo-redundant backups will be stored in multiple regions to ensure data availability in the event of a regional disaster.

The platform must include a disaster recovery plan with detailed procedures for restoring services in case of a major failure.

This example of an SRS provides a comprehensive overview of functional requirements, security measures, asset management, and environmental considerations, ensuring the platform is secure, reliable, and compliant with regulations.